CYBER THREAT INTELLIGENCE

CTI Warehouse

A data-mining pipeline that ingests security events, classifies attacks, mines anomalies, correlates evidence into alerts, and presents it all through an investigation dashboard.

Data Mining Project

FastAPI · PostgreSQL · React

What the system does



Preserve

Ingest & store security events exactly as observed



Classify

Label known attack patterns (supervised ML)



Mine

Flag anomalous behaviour (unsupervised ML)



Enrich

Match threat indicators & MITRE ATT&CK



Correlate

Group evidence into alerts with a risk score



Present

Investigation dashboard, every number API-backed

Design principle: *facts ≠ predictions ≠ analyst conclusions. Anomalies are not attacks, scores are not probabilities, and alerts are hypotheses — each is stored and labelled separately.*

Architecture — a modular monolith

React / TypeScript dashboard

TanStack Query · Recharts · talks to the backend only via one API client

FastAPI backend (api → services → repositories / domain)

Routers hold no SQL or business logic; domain modules never import the API

Background worker (job queue)

Training, scoring, matching, correlation run as jobs — never inside a request

PostgreSQL warehouse (star schema, partitioned, Alembic migrations)

Facts, ground truth, model outputs, alerts — in separate tables

Runs natively (local PostgreSQL, uv, npm). Docker Compose optional. No Kafka / Spark / microservices — a single deployable system.

The data-mining pipeline



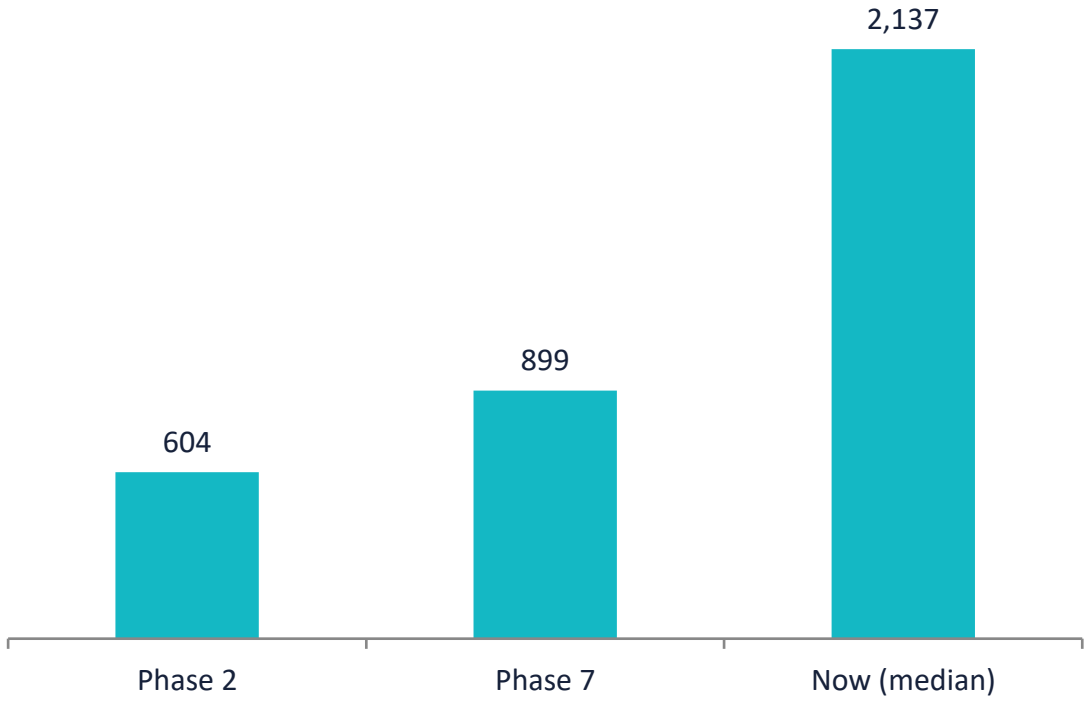
Investigation dashboard

Overview · Events · Classification · Anomalies · Threat intel · Alerts · Cases · Models — every value drawn from a real API response, with honest empty states.

Ingestion — fast, validated, idempotent

- Adapters for canonical JSON, CSV, CIC-IDS2017, UNSW-NB15, and Nginx/Apache access logs
- Every record validated & normalised to canonical fields; bad rows rejected with a reason
- SHA-256 fingerprint dedup — re-importing a file creates no duplicates
- Resumable batches: parallel chunk writers that still commit in order

Throughput (rows / second)



NFR-03 target 2,000 rows/s — met at the median (one run 1,952). Measured on a 180,784-line synthetic file; not yet on UNSW-NB15.

Supervised classification — two models

Network-flow classifier

attack_classifier

- Classifies network flows / events into attack categories (DoS, recon, brute force, web attack, …)
- Leakage-aware grouped splits; preprocessing fit on train only
- Reports per-class precision/recall, macro-F1, weighted-F1, confusion matrix — never accuracy alone
- Measured on synthetic data; public-dataset evaluation pending (dataset not present)

Web payload classifier

web_attack_classifier

- Classifies one HTTP parameter value: BENIGN · SQLI · XSS · PATH_TRAVERSAL · CMDI
- Char n-gram TF-IDF + logistic regression; template-grouped split
- Trained on the public HTTPParamsDataset (real data)
- Separate task & artifact — the two models never share inputs

Web payload classifier — measured results

0.9835
test macro-F1

0.9992
weighted-F1

6,210
held-out rows

Per-class F1 (grouped held-out test split)



Honest reading

The dataset is clean and tool-generated, so near-perfect scores mean ***"separable here,"*** not production accuracy.

An out-of-distribution check flagged only 39.6% of real code samples — the model generalises poorly beyond its training style. Scores are uncalibrated, not probabilities.

Anomaly mining & threat enrichment

Anomaly detection (unsupervised)

- Unsupervised per-entity windows (host / account / src IP)
- Isolation Forest and robust z-score methods
- Stores an anomaly score + percentile, not a verdict
- “Anomalous” means unusual — explicitly not “malicious”

Threat intelligence & ATT&CK

- Exact matching of events against threat-intel indicators (CSV / STIX 2.1)
- Feeds carry reliability & confidence; TAXII 2.1 polling
- Events linked to MITRE ATT&CK techniques
- A match means a value is on a list — not proof of compromise

Correlation → alerts → transparent risk

Rules are data, not code

- Versioned rules validated against a field/operator allow-list — no SQL, no regex, no eval
- Evidence types: events, classifications, anomalies, indicator matches, web-payload results
- Example: ≥ 2 attack-like HTTP parameters from one client within an hour → one alert
- Alerts are hypotheses for an analyst — deduplicated, never silently reopened

risk_v1 — a transparent 0–100 score

Additive, explainable — not a probability



The dashboard shows this breakdown so an analyst sees exactly why a score is what it is.

Live demo — web attacks, end to end

Demo site
local echo target
(safe, never executes)

→

Access log
each request
written to a log

→

Live tail
new lines ingested
every few seconds

→

Score + alert
classify params,
raise alerts

50	39	3
requests sent	parameters scored	alerts raised

Verified run: the four planted payloads were classified SQLI, XSS, PATH_TRAVERSAL and CMDI, and each attacking client produced one alert — nobody else did. A dashboard “Live” toggle refreshes the view every 10 seconds.

Engineering quality & security

558

backend tests passing

73

frontend tests passing

8

roadmap phases delivered

- **Reproducible ML** — every training run records seed, dataset hash, feature & label versions, library and code versions
- **Schema via migrations** — all changes through Alembic; upgrades & downgrades tested on empty and prior-head databases
- **Security controls** — RBAC on every endpoint, parameterised SQL only, size-limited uploads, audit log on every change
- **Least-privilege DB** — separate migration-owner vs. DML-only app role; privileged ops behind SECURITY DEFINER functions
- **Honest dashboard** — every number comes from a real API response; empty data shows an honest empty state

Honest limitations

Public datasets not yet run

The network-flow classifier is trained on synthetic data; UNSW-NB15 / CIC-IDS2017 evaluation is pending download.

Docker path not exercised

Runs natively and is fully tested that way; the optional Docker Compose path has not been run here.

Detection, not prevention

The system flags and scores — it never blocks traffic. Alerts are hypotheses for a human analyst.

Models reflect their data

Expect false positives on unusual but legitimate input; analyst feedback is captured but never overwrites a prediction.

A pipeline you can trust

Ingest → classify → mine → enrich → correlate → present — end to end, tested, and demonstrable live.

Its defining quality is honesty: facts, predictions, and conclusions stay separate, every dashboard number is real, and the limitations are stated out loud.

Thank you

Questions welcome